

Aktuelle Entwicklungen und Ausblick zum IT-Grundschutz

Fortentwicklung des IT-Grundschutzes zu IT-Grundschutz++



Bundesamt
für Sicherheit in der
Informationstechnik

Holger Schildt, Referatsleiter S13 - IT-Grundschutz

1. IT-Grundschutz-Tag 2025 | Magdeburg | 04.02.2025

Fortentwicklung IT-Grundschutz

IT-Grundschutz-Kompendium 2025

2018 bis 2023: Jährliche Veröffentlichung eines IT-Grundschutz-Kompendiums

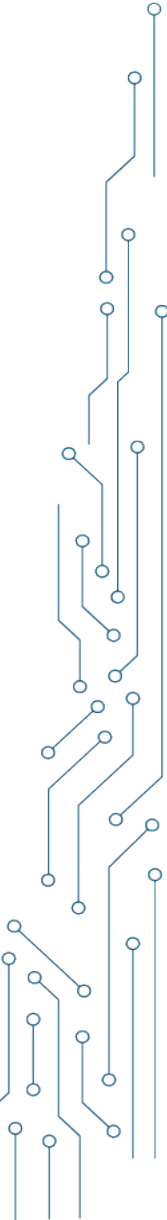
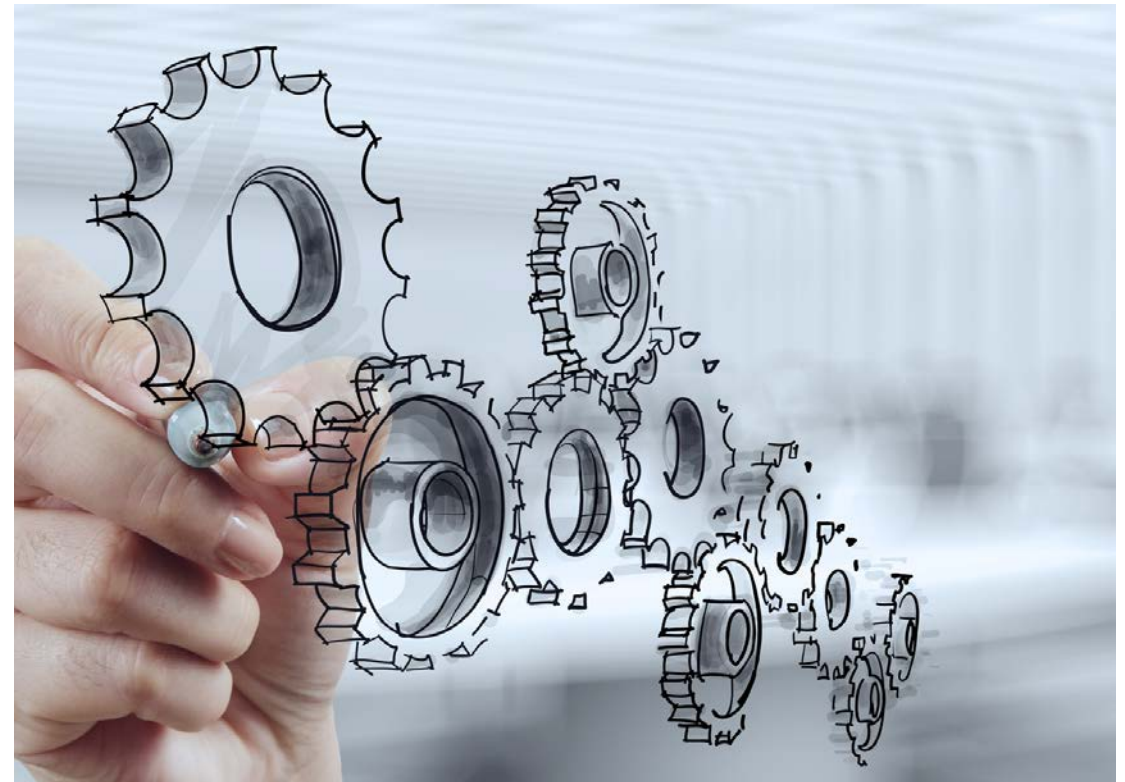
Seit 2023: Fortentwicklung „IT-Grundschutz ++“

Auch 2025 keine Veröffentlichung einer Edition

Eventuell weitere Veröffentlichung von Community und Final Drafts

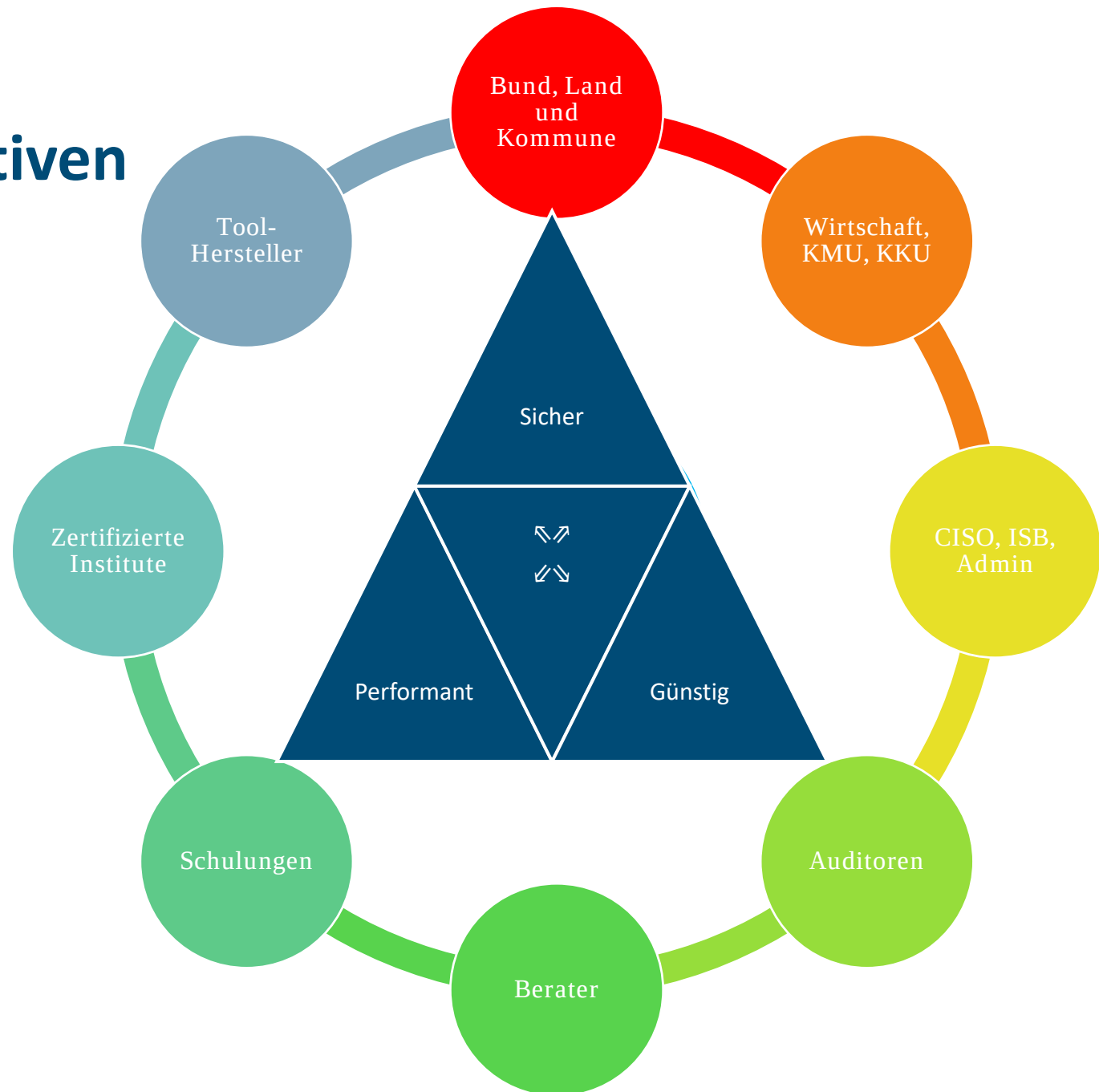
Eventuelle Fehler werden in Errata korrigiert

Keine Aufwände bei Anwendern, da nicht auf eine Edition 2025 migriert werden braucht



Stakeholder und Perspektiven

Viele Brillen, ein Bild

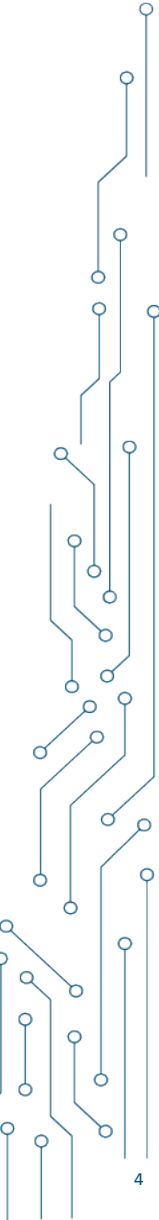


Vision IT-Grundschutz++

Wer Visionen hat, soll zum BSI gehen

*Cybersicherheit ist mess- &
automatisierbar:*

*Sicherheitsanforderungen werden als
priorisierte, maschinenlesbare Regeln
in kontinuierlichen PDCA-Zyklen
erstellt*



Automatisierung des ISMS

Anwendung datengesteuerter Werkzeuge weitgehend ermöglichen



Erfassung

- Systeme
- Daten
- Lieferanten



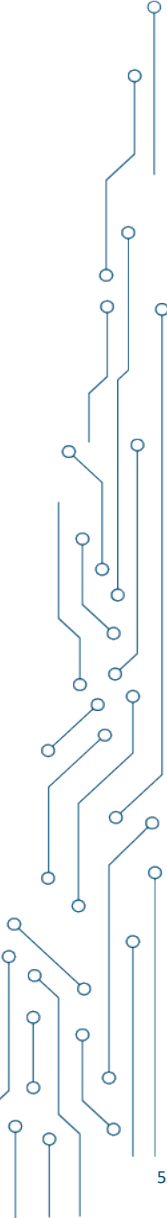
Integration

- Continuous Integration, Delivery and Deployment
- Smart Standards
- Smart Contracts



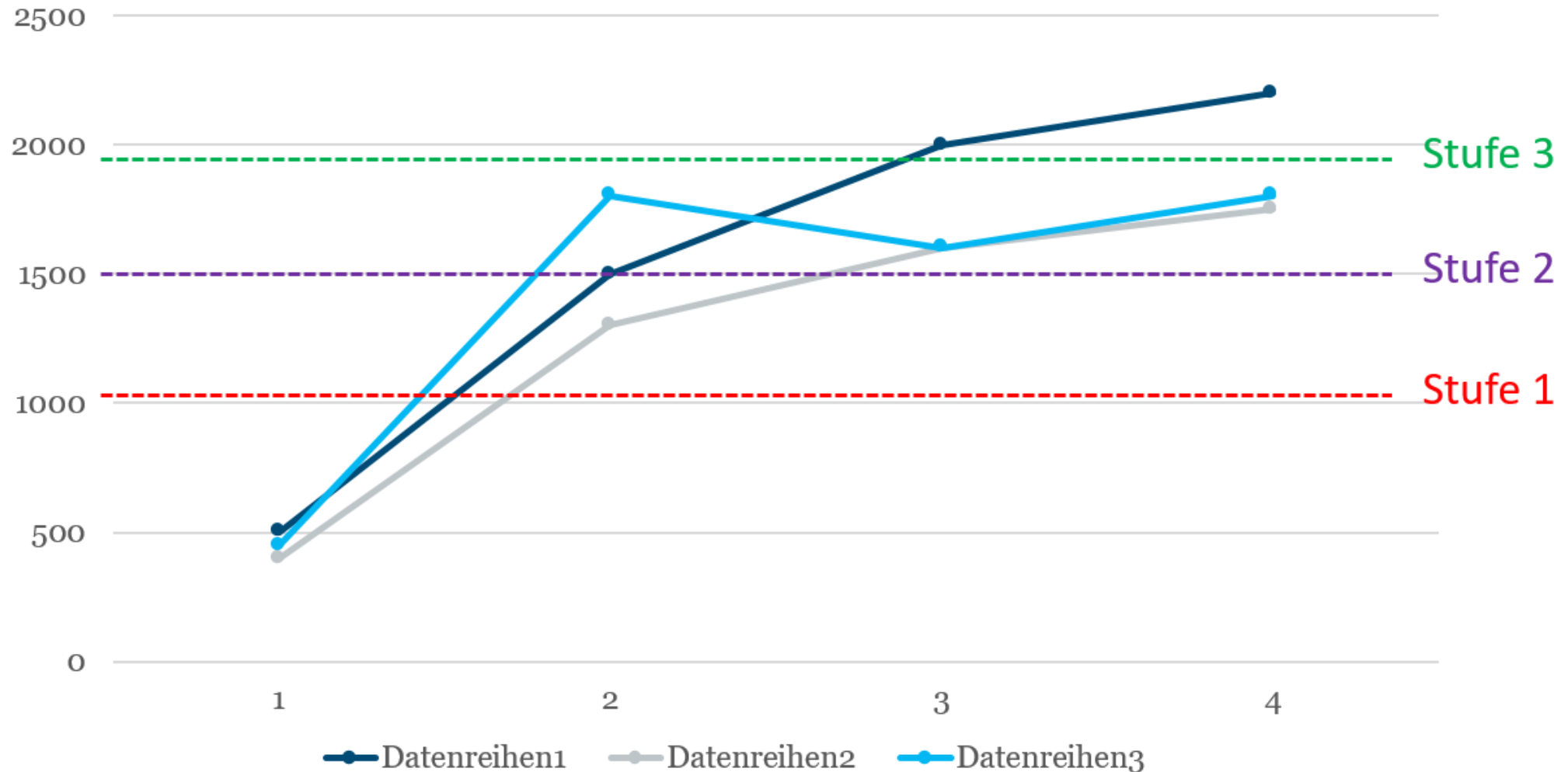
Aufrechterhaltung

- Überwachung der Konformität
- Sperrung
- Alarmierung



Kennzahlen für Entscheider

Resilienz wird messbar, vergleichbar und verständlich durch Kennzahlindikatoren



Fortentwicklung IT-Grundschutz

... und wie?

30 Jahre IT-Grundschutz: Gestern, heute, morgen

IT-Grundschutz-Veranstaltung 2024

Anfang 23.10.2024
Ende 23.10.2024
Veranstaltungsort it-sa Nürnberg

Praxisnah und flexibel. Schon 1994 war dies der Grundgedanke für die IT-Sicherheitsempfehlungen, als die erste Ausgabe des IT-Grundschutzhandbuches herauskam. Drei Jahrzehnte später hat sich nicht nur die Welt um den IT-Grundschutz geändert.

Der IT-Grundschutz wird derzeit agil weiterentwickelt. Die Ziele sind, den Umfang und die bei der Umsetzung entstehenden Dokumentationsaufwände auf das notwendige Mindestmaß zu reduzieren, eine Priorisierung der Anforderungen vorzunehmen, eine Leistungszahl aus den umgesetzten Anforderungen zu errechnen sowie die Anwendung von Automatisierungstools weitestgehend zu ermöglichen.

Die Veranstaltung blickte auf 30 Jahre IT-Grundschutz zurück und erinnerte an die Höhepunkte der letzten drei Jahrzehnte. Anschließend wurde zusammengefasst, was den IT-Grundschutz derzeit auszeichnet und wo er steht. Mehrere Vorträge informierten über den aktuellen Stand der agilen Weiterentwicklung und zeigten, was das zukünftige IT-Grundschutz auszeichnet.

Zu den Folien: [30 Jahre IT-Grundschutz: Gestern, heute, morgen](#)

Zu der Aufzeichnung: ["30 Jahre IT-Grundschutz: Gestern, heute, morgen" auf YouTube](#)

Haben Sie noch Fragen oder Feedback?
Dann schreiben Sie uns gerne an it-grundschutz@bsi.bund.de

Agenda:

Uhrzeit	Thema

https://www.bsi.bund.de/SharedDocs/Termine/DE/2024/IT_Grundschutzveranstaltung_2024.html

Filtern und Verstehen durch Metadaten

Genau das sehen, was Sie jetzt brauchen



Praktiken

- Prozesse des ISMS
- Strategie, Taktik, Operativ



Handlungsworte

- Definierte Tätigkeiten
- Mensch oder Maschine



Zielobjekte

- Technik: Server, Linux, ...
- Organisatorisch:
Standorte, Adressaten, Verträge, ...



Hinweise

- Ziele und Definitionen
- Umsetzungshinweise



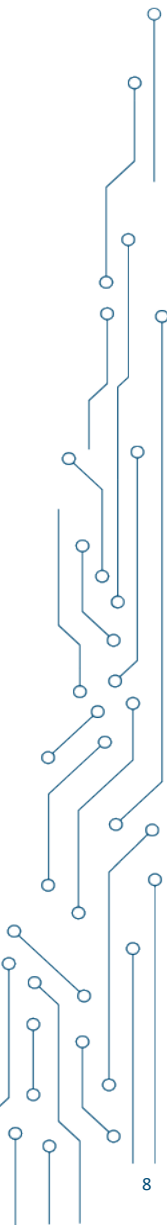
Stufe 0-5

- Von Quick-Win bis Nice-to-have
- Von Jeder bis erhöhter Schutzbedarf



Tags

- Querschnittsthemen
- Trends im Fokus



Filtern und Verstehen durch Metadaten

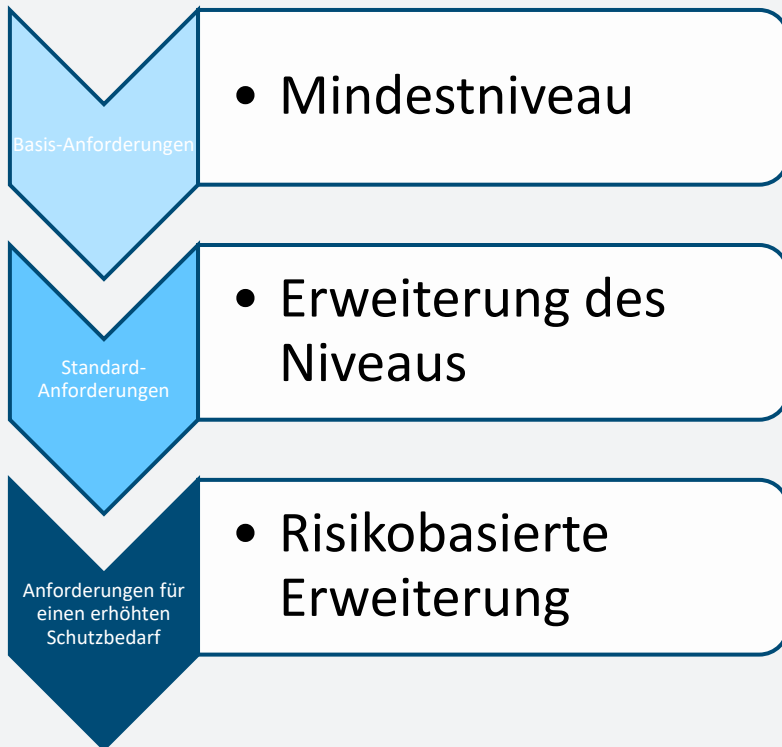
Genau das sehen, was Sie jetzt brauchen

Praktik	Zielobjekt	MODALVERB	Ergebnis	Handlungswort	Hinweis	Tags
Konfiguration	IT-Systeme	SOLLTE	nicht benötigte Funktionen	deaktivieren	Deinstallieren oder Deaktivieren Sie Funktionen, die für Betrieb oder Sicherheit nicht benötigt werden, z.B. ungenutzte Cloud-Anbindungen, Module oder Einstellungen.	Hardening
Sensibilisierung	Benutzende	SOLLTE	die Weitergabe von personengebundenen Authentisierungsmitteln	verbieten	Personengebundene Authentisierungsmittel sind z.B. Passworte, Private PKI-Schlüssel oder Mehr-Faktor-Authentifizierungstoken wie Smartcards.	
Detektion	VPN-Gateways	SOLLTE	VPN-Verbindungen auf unberechtigte Einwahlen	überprüfen	Kann manuell oder durch automatische Analyse von Logdateien erfolgen. Dabei kann z.B. nach ungewöhnlichen vielen fehlgeschlagenen Anmeldungen, veralteten Berechtigungen, Einwahlen von Adminaccounts, ungewöhnlichen Einwahlorten/IP-Adressbereichen/User Agents oder Uhrzeiten gesucht werden.	Zero Trust, Advanced Persistent Threats (APT)

Wo bleibt das (Sicherheits-)Niveau?

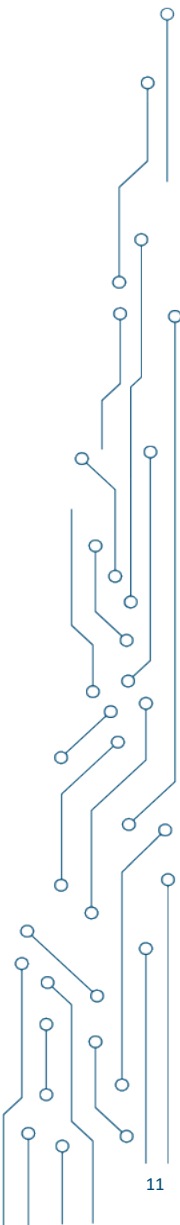
Zukünftige Mess- und Vergleichbarkeit im IT-Grundschutz

IT-Grundschutz



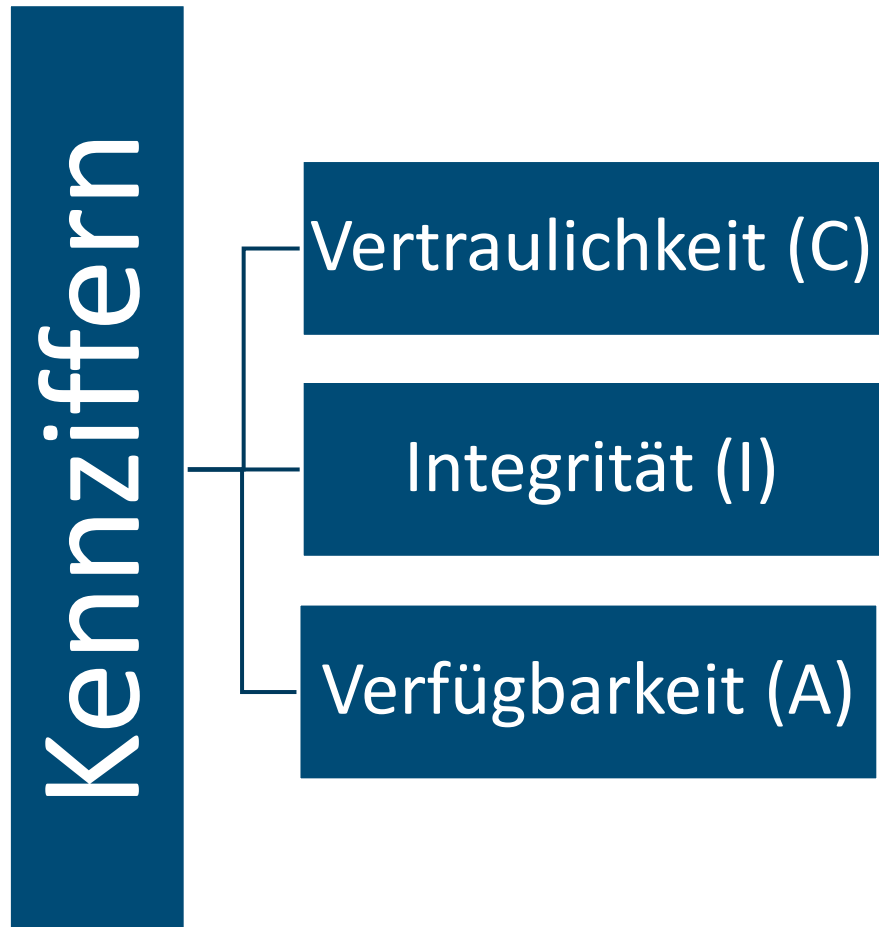
Die Stufen

Was mache ich zuerst

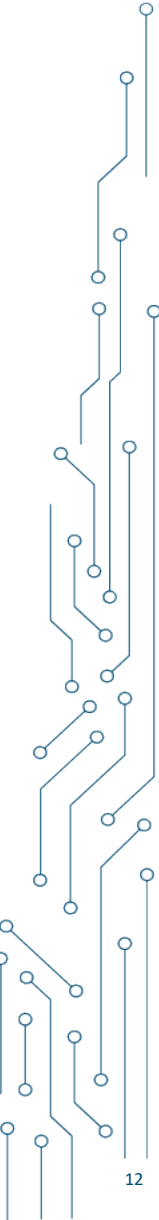


Die Leistungskennzahlen

Was bringt mir eine Anforderung?



Wie Effektiv ist die
Anforderung in der
Behandlung EINER
Gefährdung



Die Schwellwerte

[Stufe 1] Sensibilisierung
gegen die Bild- und
Tonaufzeichnung ohne
vorherige Ankündigung
an alle Betroffenen

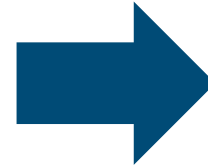
- Vertraulichkeit : 6
- Integrität: 0
- Verfügbarkeit 0

[Stufe 1]
Der IT-Betrieb legt
zeitnahe Installation von
Sicherheitsupdates fest

- Vertraulichkeit [4]
- Integrität [3]
- Verfügbarkeit [4]

[Stufe 1]
....

- Vertraulichkeit [X]
- Integrität [Y]
- Verfügbarkeit [Z]



Schwellwert 1

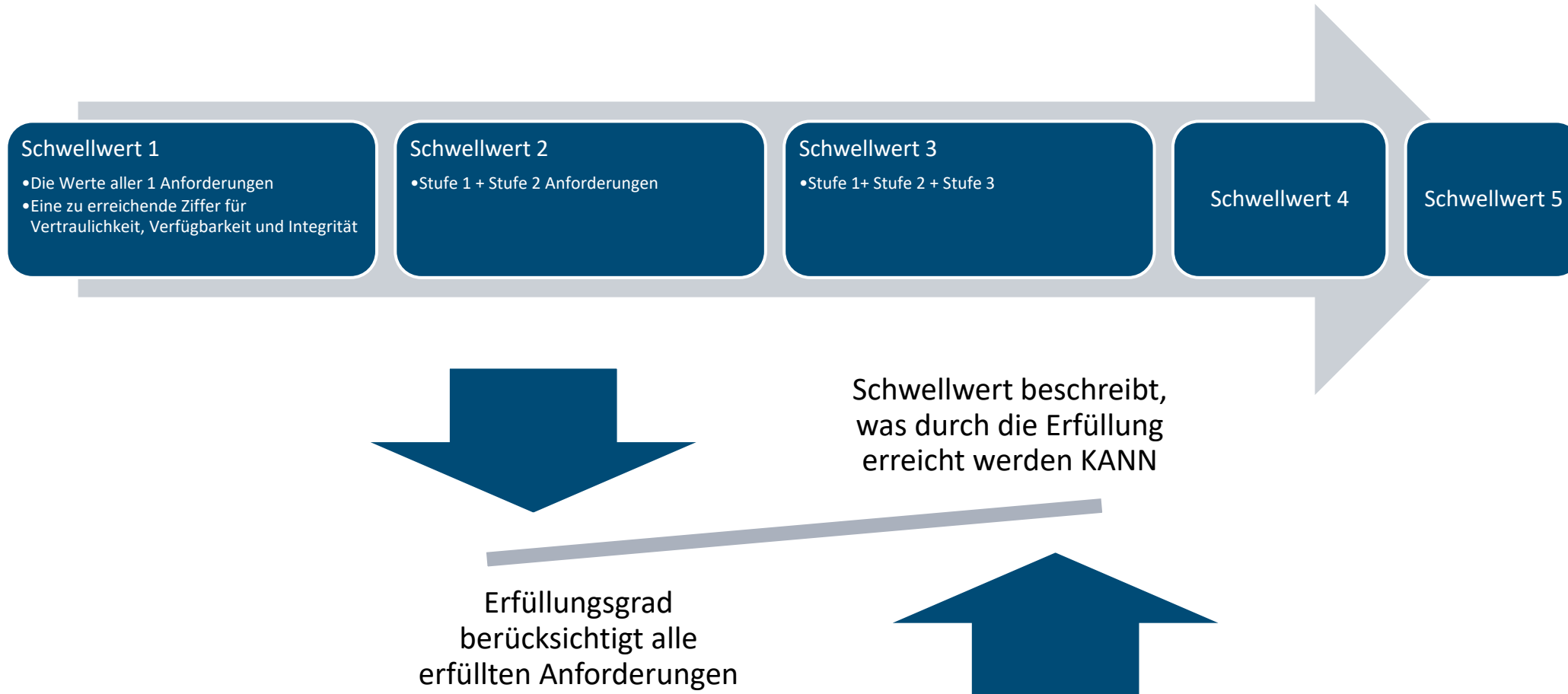
☐ Vertraulichkeit [10+X]

☐ Integrität [3+Y]

☐ Verfügbarkeit[4+Z]

Die Schwellwerte

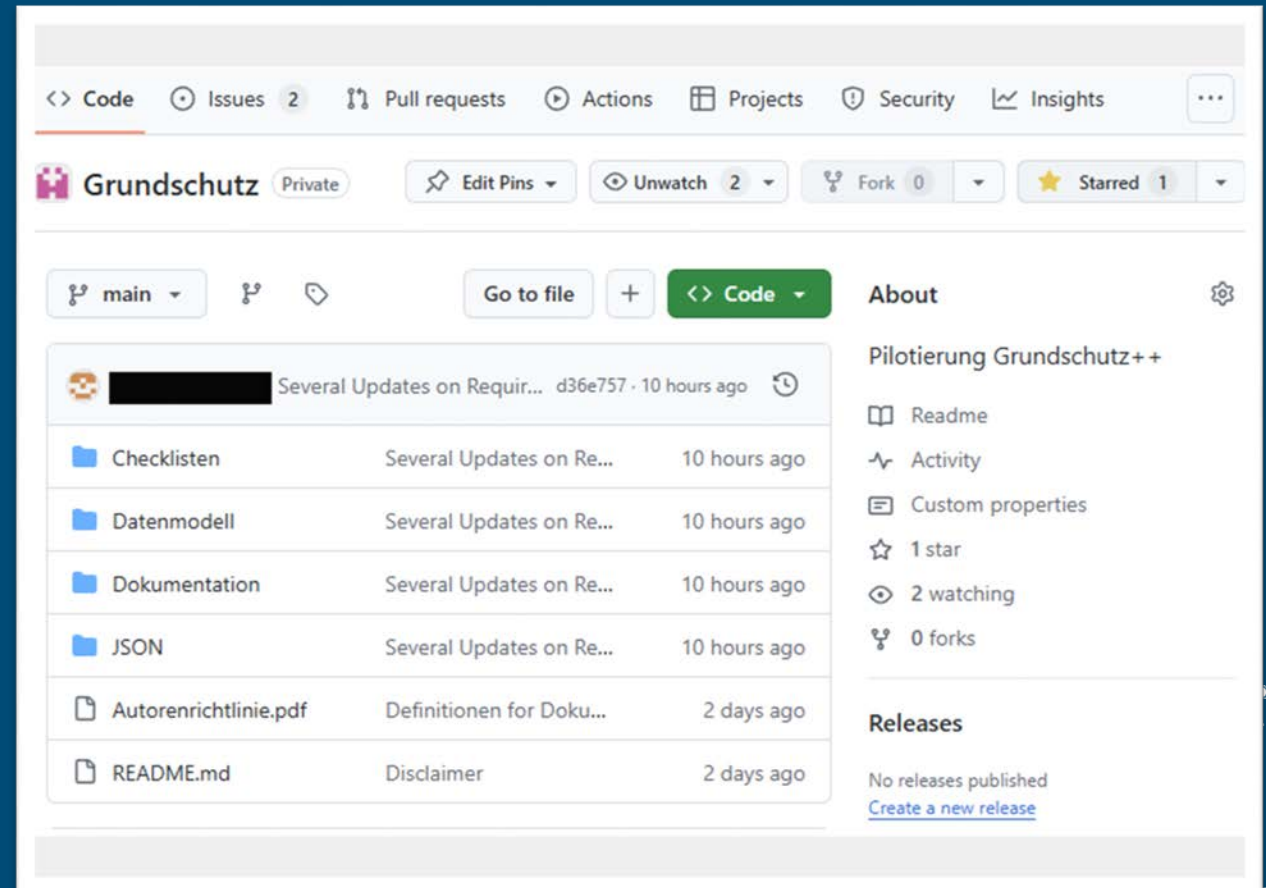
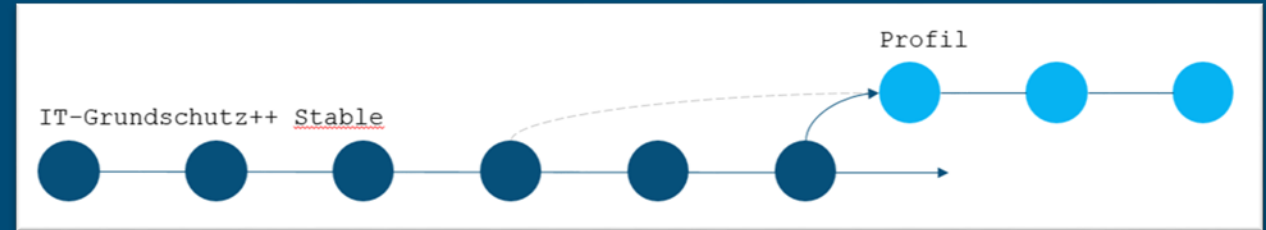
Zusammenspiel mit Erfüllungsgrad



Transparenz und Engagement in der Community

Werkzeuge für jede Façon.

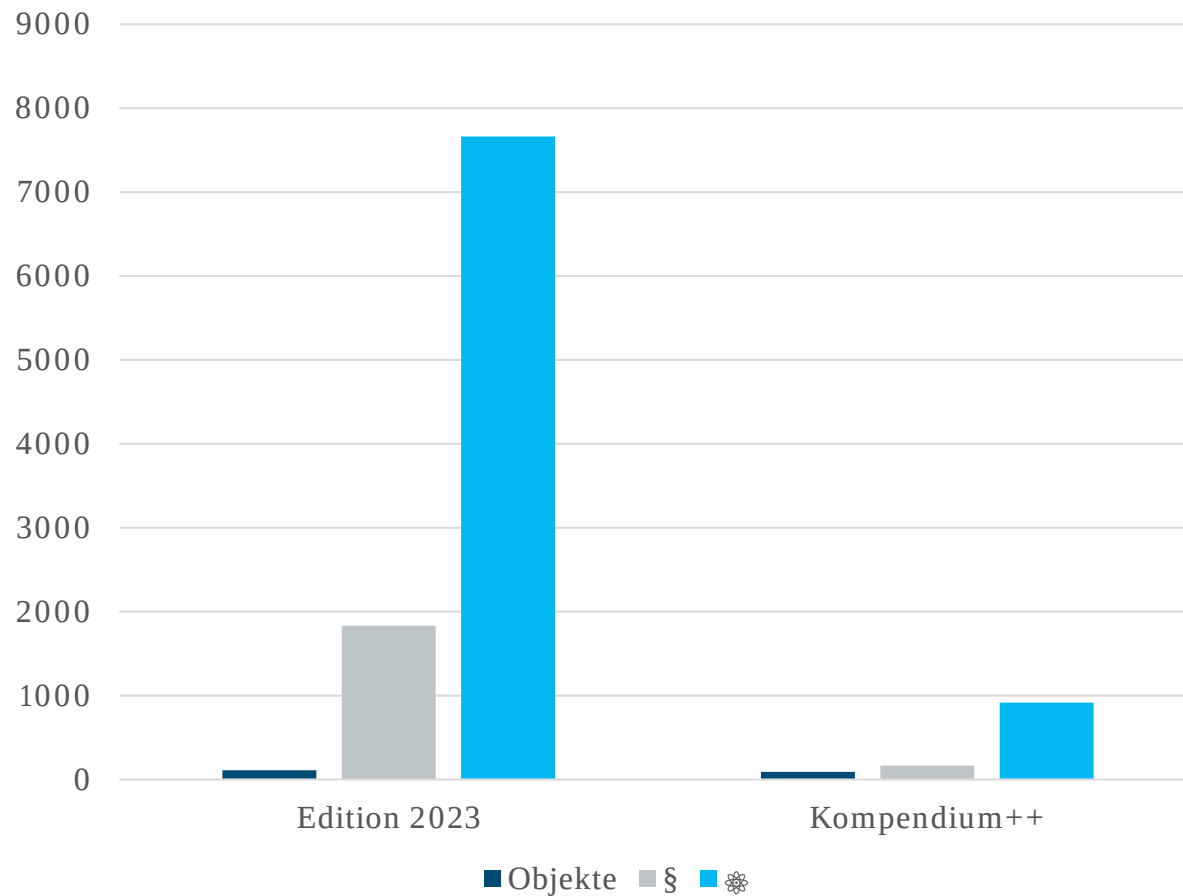
- **Download** in JSON und XLSX
- **Benachrichtigung** bei Änderungen per E-Mail oder Webhooks
- **Versionierung** mit Branches für Stabilität und Dynamik
- **Feedback** über Issues, Pull Requests und Discussions
- **Individualisierung** über Forks und Scripting



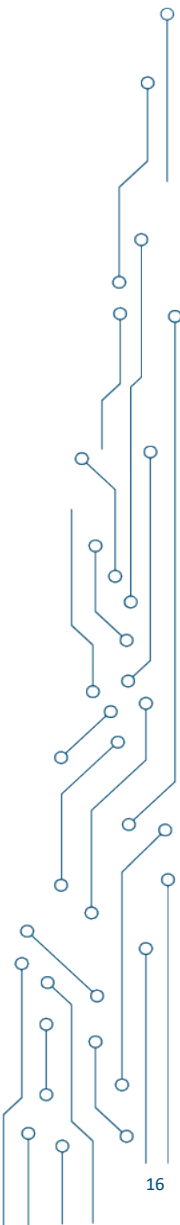
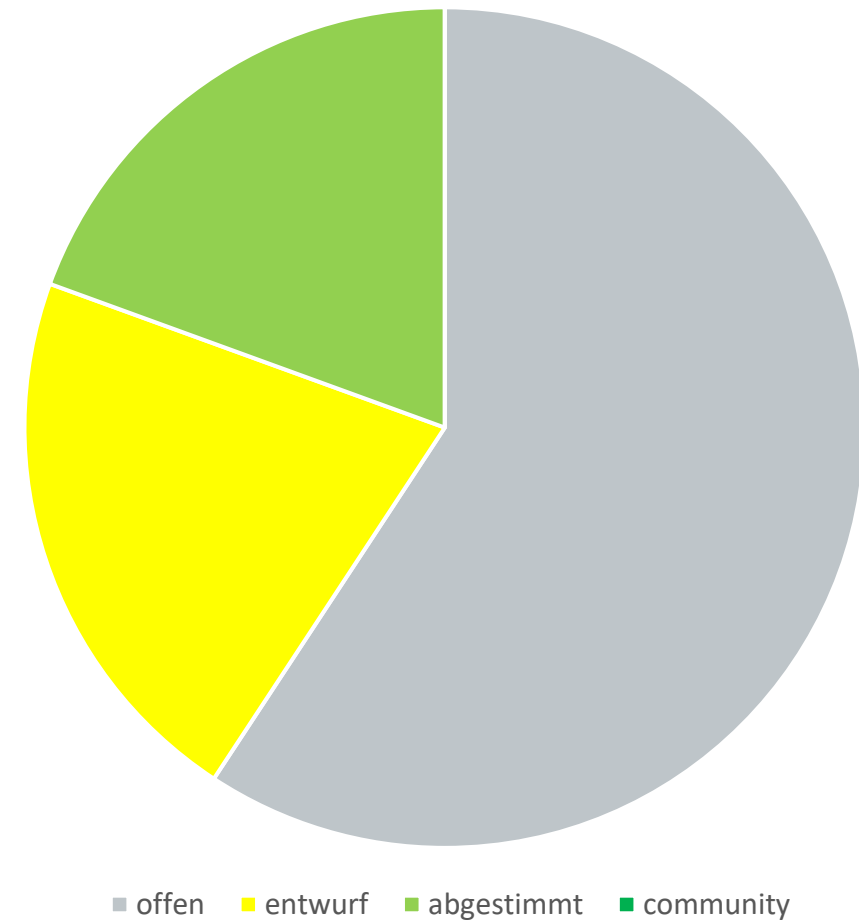
Sachstand

Wie viel ++ steckt schon im neuen Kompendium?

Umfang



Überführung



Mehrwert



Schneller im Ziel durch
Filtern, Automatisieren und Vereinheitlichen



Fortschritt dynamisch messen
mit Kennzahlindikatoren



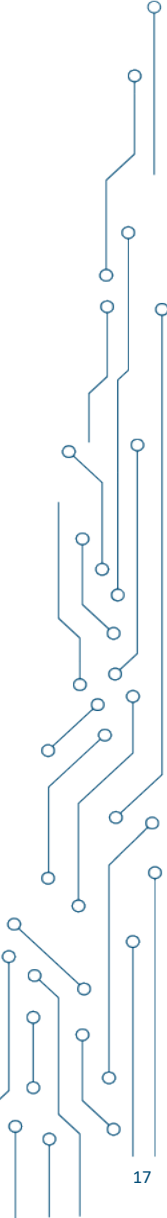
Bewährte Inhalte,
klarer formuliert und erklärt



Anpassung an
technische und rechtliche Neuerungen

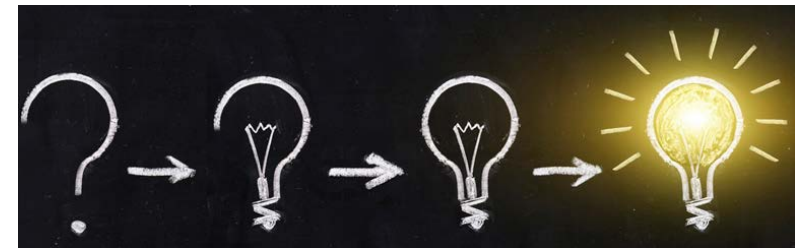


Agile Veröffentlichung,
zeitnah und nachvollziehbar



Zusammenarbeit

Wie können Sie bei der Pilotierung mitarbeiten?



Wo?
Videokonferenz

Wie lange?
2 Stunden

Teilnahme an einem digitalen Beteiligungsworkshop.

Agenda:

- ✓ Kurze Vorstellung des IT-Grundschutz++ Konzeptes
- ✓ Workshop: Erarbeitung von Formaten zur Unterstützung und Pilotierung des neuen Konzeptes
- ✓ Commitment zur Kooperation und Zusammenarbeit in der Pilotphase

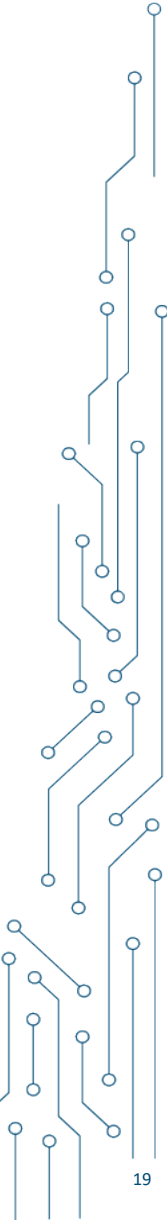
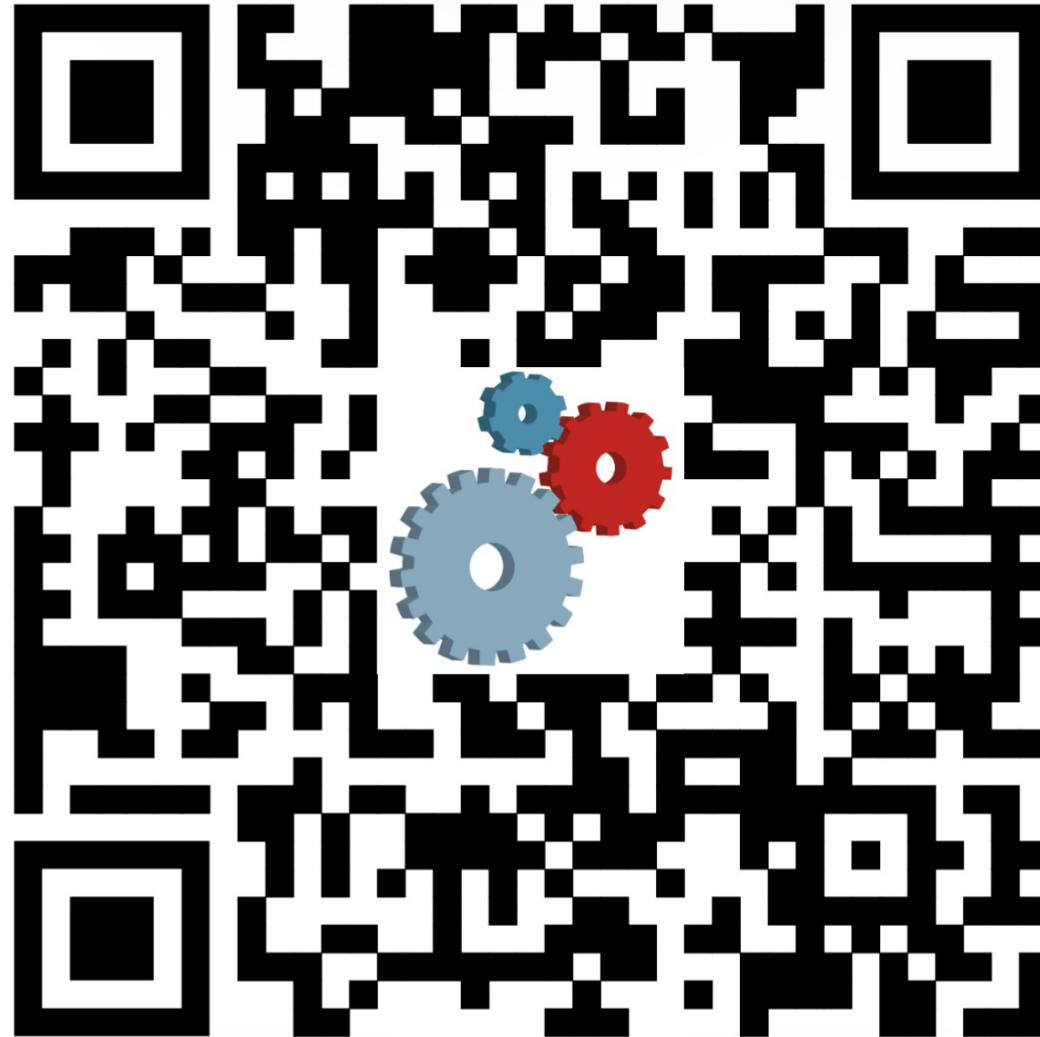
Wann?
25.02.2025

Wer?
Jeder mit IT und GS-Kenntnissen

Wie teilnehmen?
www.bsi.bund.de/dok/GS-Workshop
QR-Code auf der nächsten Folie

Beteiligungsworkshop „Digitales Kompendium“

Anmeldung





Bundesamt
für Sicherheit in der
Informationstechnik

Vielen Dank für Ihre Aufmerksamkeit!

IT-Grundschutz++ Team

it-grundschutz@bsi.bund.de

Tel.: +49 (0) 228 9582 0

Bundesamt für Sicherheit in der Informationstechnik (BSI)

Godesberger Allee 87

53175 Bonn

www.bsi.bund.de

Follow us:

